SOFTWARE PROJECT REPORT

waapi

Commercial multi-tenant WhatsApp HTTP API (unofficial, Baileys-based) — closed-beta software status through Phase 4 (complete).

Phase 1–3 complete | Phase 4 Tier-1 complete | Monorepo pnpm

Document type: Project report (overview for handoff / Claude)

Companion doc: Source Code Documentation PDF

Branch tip (at generation): phase-4 (reports refresh; includes ff02a85 + this commit)

PR: https://github.com/SyedIsmail-47/waapi/pull/4 (phase-4 → main) — open, do not merge until approved

Date: 22 October 2026

Classification: Public engineering docs — no secrets

1. Executive summary

waapi is a pnpm monorepo that exposes a Fastify `/api/v1` API and React dashboard for managing unofficial WhatsApp sessions (Baileys), outbound text send, HMAC-signed webhooks, invite-gated signup, trial + Paddle billing, and an internal admin CLI. A static marketing site (`apps/site`) is built for Cloudflare Pages.

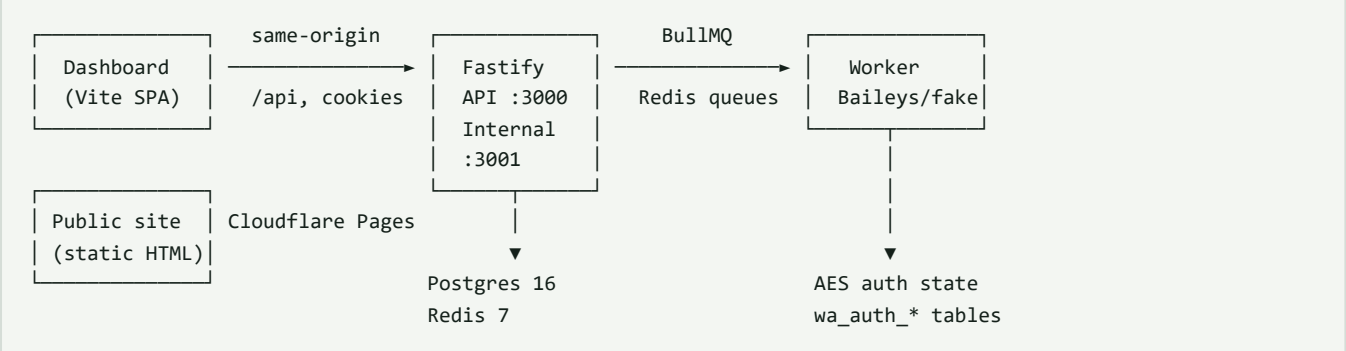
Phases 1–3 (worker, API, dashboard) are shipped. Phase 4 closed-beta Tier-1 work packages **A–G, J, L, M, N** are merged into `phase-4` . Final PR `phase-4 → main` is open (#4). Empty branch `phase-5-parity` exists for the next phase. Tier-2 media/groups (H) and webhook event parity (I) are intentionally not started.

> **Product disclaimer:** Unofficial client. Not affiliated with WhatsApp or Meta. Account ban risk is real and disclosed on the public site footer and legal drafts.

2. Goals of closed beta

- Invite-only signup with Turnstile; terms acceptance stored at register.
- Deterministic `WA_DRIVER=fake` for CI/e2e without live WhatsApp.
- Trial billing (default 3 days, 1 session) with 402 enforcement when expired.
- Paddle webhook verification on exact raw body; plan allowlist; manual review for refunds/pauses.
- Ops: preflight env check, age-encrypted off-box backups, Origin CA nginx, runbook + Paddle go-live checklist.
- Never log/store message bodies, tokens, or secrets in plaintext application logs.

3. Architecture overview



Component	Role
`apps/api`	Auth, sessions, send, webhooks, billing, internal admin
`apps/worker`	Session lifecycle, QR, send-text jobs, Baileys/fake driver
`apps/dashboard`	Operator UI (sessions, messages, settings, billing)
`apps/site`	Prerendered marketing + legal (DRAFT)
`packages/db`	Drizzle schema + numbered migrations 0000–0011
`packages/shared`	Zod schemas, plans, brand, error codes

4. Phase delivery history

Phase	Scope	Status
1	Worker, encrypted auth state, CLI, compose, vitest	Done
2	API auth, sessions, send, webhooks, SSRF, outbox, rate limits	Done
3	Dashboard SPA, cookies/CSRF, Turnstile, smoke e2e	Done — tagged `phase-3-final`
4	Closed-beta Tier-1: fake driver, invites, email/account/session UX, billing, admin, site/legal, go-live, security, reliability	**Complete** — PR #4 open
5	Parity / stretch (branch created empty)	`phase-5-parity` ready; H/I not started

5. Phase 4 work packages

WP	Name	Tier	Result
A	Fake WhatsApp driver + Playwright smoke	1	Merged
B	Closed beta gate (`SIGNUPS_MODE` , invite codes)	1	Merged — migration 0008
C	Email UX (`PUBLIC_APP_URL` , HTML/text templates)	1	Merged
D	Account lifecycle (password, resend verify, delete)	1	Merged
E	Session UX (disconnect/logout/delete/rename, QR expiry)	1	Merged
F	Billing core (trial, plans, Paddle adapter)	1	Merged — migration 0009
G	Admin CLI (internal HTTP + `pnpm admin`)	1	Merged
J	Public site + legal + terms at signup	1	Merged — migration 0010
L	Go-live prep (preflight, encrypted backup, nginx Origin CA)	1	Merged — docs/scripts
M	Security pass (redaction, nginx, age backups, guards, ZAP triage)	1	Merged — triage kept in private ops pack
N	Reliability (alerts, send limits, Paddle N1–N8, e2e CI)	1	Merged — migration 0011
H	Media + groups	2	Not started (stretch)
I	Webhook event parity	2	Not started (stretch)

Process: test-first per WP; merge to `phase-4` only when CI green; never merge to main until final PR; never `--admin` .

5.1 WP-N detail (N1–N8)

ID	Result	Evidence
N1	OK	Raw Buffer parser + HMAC `ts:rawBody` , multi-h1, ±5m; never re-stringify
N2	OK	Price allowlist → plan; unknown price audit; customer bind from custom_data after verify
N3	OK	updated/paused/resumed/adjustment.* → manual review (no auto-suspend); fixtures per event
N4	OK	Enforcement matrix: billing states × JWT/PAT/session key × actions; BILLING_EXPIRED 402
N5	OK	Production cookie flags (HttpOnly/Secure/Strict/Path); logout clears
N6	OK	Playwright e2e job in CI; required check on public `main`
N7	OK	OWASP ZAP baseline vs smoke: FAIL-NEW 0; triage in private ops pack
N8	OK	Stripe mentions removed; Paddle go-live checklist in runbook; packs + PDFs

Also in WP-N: disconnect email alerts (6h dedupe, opt-out), per-plan send limits with warm-up, `PHONE_IN_USE` UX, billing sweeper.

6. Product features (what exists)

6.1 Auth & tenancy

- Register / login / refresh / logout with JWT access + HttpOnly refresh cookie
- CSRF double-submit on cookie-mode refresh/logout; production cookie Path=/api/v1/auth
- Email verify + password reset (Resend/SMTP/console drivers)
- `SIGNUPS_MODE=open|invite|closed` (default invite)
- Terms checkbox → `users.terms_version` + `terms_accepted_at`
- PATs and per-session API keys; account-scoped queries (tenant isolation tests)

6.2 Sessions & messaging

- Create / connect / disconnect / logout / delete / rename
- QR via Redis pub/sub; fake driver for CI
- Send text with idempotency; plan warm-up + day/minute send counters
- Disconnect alerts (email); unique phone → `PHONE_IN_USE` 409
- Webhook endpoints with HMAC signatures; SSRF-safe URL checks; encrypted outbox

6.3 Billing

- Plans in `packages/shared/src/plans.ts` (trial/starter/pro/enterprise)
- States: trialing / active / past_due / canceled / expired + grace; paused flagged for review
- 402 `BILLING_EXPIRED` on create/send when expired; billing GET + delete-account always allowed
- `BILLING_PROVIDER=manual|paddle` only (no Stripe); no card data stored
- 5-minute billing sweeper; admin CLI `manual-review`

6.4 Ops

- `pnpm admin` — find user, suspend, set plan, revoke keys, force logout, invites, manual-review
- `pnpm preflight` — production env gate (no secret echo)
- `scripts/backup-pg.sh` / `restore-pg.sh` — age-encrypted dumps + sha256
- `deploy/nginx.conf` — Cloudflare Origin CA, HSTS/CSP, CF real_ip ranges

7. Data model (high level)

Area	Tables (selected)
Tenancy	accounts, users, refresh_tokens, personal_access_tokens
Sessions	sessions, session_api_keys, wa_auth_creds, wa_auth_keys
Messaging	message_logs, outbound_messages, session_send_counters (0011)
Webhooks	webhook_endpoints, webhook_outbox, webhook_deliveries
Beta	invite_codes (0008)
Billing	subscriptions, billing_events (0009); accounts.manual_review_* (0011)
Legal	users.terms_version, terms_accepted_at (0010)
Reliability	disconnect_alerts_opt_out, last_disconnect_alert_at (0011)
Audit	security_audit_log, login_attempts

8. Testing & CI

- Vitest: **306 passed, 2 skipped** (308 total) under `CI=true` — skips are `backup-restore` age/gzip and live-DB probes
- Playwright e2e on smoke stack (signup → verify → session → fake scan); required check on public `main`
- GitHub Actions jobs: `build`, `gitleaks`, `e2e (smoke + playwright)`; workflow `permissions: contents: read`
- Stable green run example: `39761141553` (phase-4 merge tip)
- Route / billing enforcement matrix tests; ZAP FAIL-NEW 0 against smoke

8.1 Manual acceptance & RAM (operator)

- **Phone send/receive** (incl. outbound to a contact), **network drop**, **phone logout** — completed by operator; noted in `docs/runbook.md`
- **RAM probe** (`pnpm ram-probe`, in-memory slot sim, 2026-10-22): 0→74.8 MB, 1→75.3, 3→76.8, 5→79.3, 10→84.3 MB — table filled in runbook §9
- Still optional on VPS: kill -9 recovery, 440 replaced, node cap, live Baileys RSS vs probe

8.2 Public exposure audit (post go-public)

- gitleaks + trufflehog over all refs: **no secrets found**
- Security-pass + Claude handoff removed from public tree (`2b2b6fe`); copies only in local private ops pack
- Runbook host/rclone example paths sanitized to placeholders
- Verdict: no credential rotation required; personal commit email still in history (noreply switch pending)

9. Known gaps & risks

- Tier-2: media/groups send (WP-H); broader webhook event types (WP-I)
- Legal pages marked **DRAFT** — lawyer review required before public claims
- Unofficial WhatsApp protocol / ban risk
- ZAP WARN-NEW items deferred/accepted (private ops pack; not published)
- Nothing is auto-deployed from this repo; go-live is manual VPS + Cloudflare
- PR #4 not yet merged to `main` (intentional until you approve)
- Review packs (`review-pack-*.md`) are gitignored — upload privately if needed for review

10. How to run locally

```
cp .env.example .env   # fill 32-byte keys
pnpm install
pnpm docker:up
pnpm db:migrate && pnpm seed
pnpm dev:api
pnpm dev:worker
pnpm dev:dashboard     # http://127.0.0.1:5173
pnpm build:site        # apps/site/dist
```

11. Documents map

Path	Purpose
`docs/runbook.md`	Ops, smoke, admin, billing, Paddle checklist, RAM table, phone acceptance
`docs/design/billing.md`	Billing design (manual + Paddle)
`docs/reports/waapi-project-report.pdf`	This report
`docs/reports/waapi-source-code-documentation.pdf`	Source tree & module guide
Private ops pack (local only)	WP-M/ZAP triage + Claude handoff (not in public git)

Generated for engineering handoff. Contains no production secrets, tokens, or message bodies. Brand name is env-driven (`BRAND_NAME`); default fallback `waapi` . Repo: https://github.com/SyedIsmail-47/waapi (public).